

PENETRATION TESTING REPORT

RECONNAISSANCE, SCANNING & WEB APPLICATION TESTING

CYBERSECURITY | ETHICAL HACKING | MEDIROZA HOSPITAL

Pentester Name (Cybersecurity Professional)	Chimanda P Mbangweta
Program/Batch	B083B-Networkwalks
Date	2 October 2026
Modules completed	Reconnaissance, Scanning, Enumeration & Exploitation
Client/Target	Mediroza Hospital
Permission secured from client?	Yes
Phases covered	Phase 1: Reconnaissance & Foot printing Phase 2: Scanning & Enumeration Phase 3: Vulnerability Validation & Exploitation

1. Liability Disclaimer

I carried out this assessment only as part of an authorized educational exercise. The Mediroza Hospital website was created for training and testing, and I had permission from my lecturer to perform the activities documented in this report. The techniques described here are for learning and defensive security purposes. They should never be used against systems without clear authorization.

2. Introduction

This report documents the penetration testing work I performed against medirozahospital.com. I started by gathering public information about the domain and identifying the technologies and services exposed by the server. I then used directory enumeration to look for hidden content and followed the findings to the patient portal.

During the web application testing stage, I identified a weakness in the patient login process that was consistent with SQL injection. After further testing, the authentication controls were bypassed and I gained access to the patient portal, where three encrypted pathology reports were available for download. The downloaded PDF files were then tested offline with John the Ripper as part of the authorized exercise.

The report follows the same practical style as the supplied sample: it records the tools used, the activities performed, the main risks, recommended fixes and supporting screenshots.

3. Tools Used

Tool	Purpose
Kali Linux	Main operating system used for the assessment.
WHOIS	Collected domain registration and name-server information.
WhatWeb	Identified web-server and application technology information.
Wafw00f	Checked whether the site was protected by a Web Application Firewall.
Zenmap / Nmap	Scanned the target host for reachable network services and SSL information.
Legion	Assisted with service discovery and automated reconnaissance.
Gobuster	Enumerated hidden directories and files, including PHP, TXT and PDF resources.
Web browser	Tested the patient portal and verified the effect of authentication weaknesses.
John the Ripper	Performed authorized offline password testing against the protected PDF files.

4. Activities Performed

4.1 Footprinting & Reconnaissance

I first used WHOIS to collect basic information about medirozahospital.com. The results showed that the domain was registered through NameCheap and used NameCheap hosting name servers. This helped me understand where the domain was hosted before moving to active scanning.

WhatWeb identified LiteSpeed as the web server and confirmed the public IP address as 199.188.201.16. I then used Wafw00f, which reported that the website was behind a LiteSpeed Web Application Firewall. These results showed that the site had some web-layer protection but also exposed enough technical information for further reconnaissance.

4.2 Network Scanning & Service Discovery

Zenmap and Legion were used to inspect the target host. Legion reported SMTP on port 25, HTTP on port 80 and HTTPS on port 443. Zenmap also confirmed the web services on ports 80 and 443 and returned SSL certificate information for the hosting server. This stage gave me a clearer picture of the externally reachable services.

4.3 Directory Enumeration

I used Gobuster to enumerate the website with the common directory wordlist and the extensions PHP, TXT and PDF. The scan returned several protected or redirected paths. This process was useful because it helped reveal content that was not obvious from the public pages, including paths connected to the patient area and exposed files.

4.4 Patient Portal & SQL Injection Testing

The patient portal was located at /patient/login.php. Normal login attempts produced an "Incorrect password" message, confirming that the application was processing the submitted credentials. I then tested the login fields for SQL injection using controlled input. An example visible in the evidence is admin' --. That particular screenshot still shows a failed login, but continued testing confirmed that the authentication logic was vulnerable and could be bypassed.

After the authentication bypass, the portal displayed three pathology reports belonging to S. Dlamini, P. Reddy and E. Thompson. Each report was available as an encrypted PDF. The files were downloaded within the authorized scope and later tested offline with John the Ripper to assess the strength of the document passwords.

5. Risk Analysis / Impact

The main findings from the assessment are summarized below. The risk levels reflect the impact demonstrated during this educational test.

#	Risk / Finding	Evidence / Observation	Potential Impact	Risk Level
1	SQL injection in patient login	Authentication controls could be bypassed during testing.	Unauthorized access to the patient portal and protected medical information.	Critical
2	Patient reports exposed after bypass	Three pathology reports became available for download.	Loss of confidentiality of sensitive medical information.	Critical
3	Weak PDF password protection	Encrypted PDFs were suitable for offline password testing.	A weak document password may allow an attacker to open downloaded records.	High
4	Hidden resources discoverable	Gobuster identified protected and redirected paths.	Helps an attacker map the application and locate sensitive areas.	Medium
5	Server and security technology exposed	WhatWeb and Wafw00f identified LiteSpeed and the WAF.	Provides useful technical details for targeted follow-up testing.	Low

6. Recommendations

- Use prepared statements or parameterized queries for every database operation, especially the login process. User input should never be inserted directly into SQL queries.
- Apply server-side authorization checks to every patient document. A logged-in user should only be able to access records that belong to that account.
- Keep backups, database exports and other sensitive files outside the public web root and block direct access to internal storage locations.
- Use strong, randomly generated passwords for encrypted medical documents and avoid relying on PDF passwords as the main access-control mechanism.
- Add rate limiting, account lockout controls, multi-factor authentication and useful security logging around the patient portal.
- Review exposed network services and close any service that is not required. Continue monitoring and tuning the existing WAF.

7. Conclusion

This exercise showed how a penetration test can move from basic reconnaissance to a meaningful security finding. Public information and service scans provided an initial picture of the target, while Gobuster helped uncover less visible web content. The most important result was the weakness in the patient login process, which allowed the authentication mechanism to be bypassed during the authorized test.

Once access was gained, the impact became clear because three encrypted pathology reports were exposed through the portal. The exercise reinforced that encryption alone is not enough when application access controls are weak. Secure SQL handling, proper authorization and strong protection of patient documents are all necessary to prevent this type of compromise.

8. Evidences Collected

The screenshots below are selected evidence from the reconnaissance, scanning, enumeration and exploitation stages.



Figure 1: WHOIS information for medirozahospital.com.

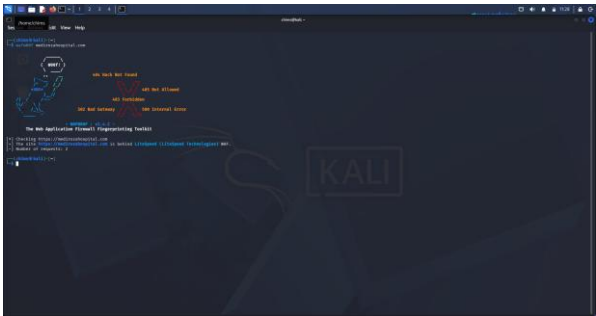


Figure 3: Wafw00f identifying the LiteSpeed WAF.

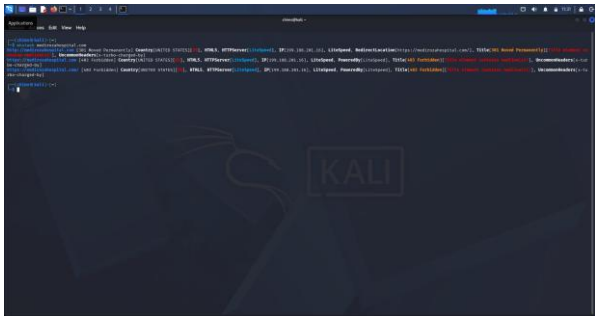


Figure 2: WhatWeb fingerprinting showing LiteSpeed and the target IP.

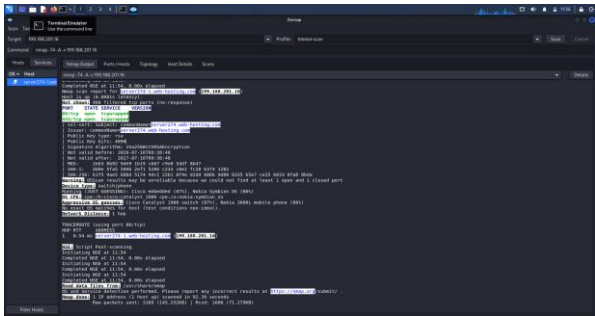


Figure 4: Zenmap/Nmap service and SSL scan results.

8. Evidences Collected (continued)

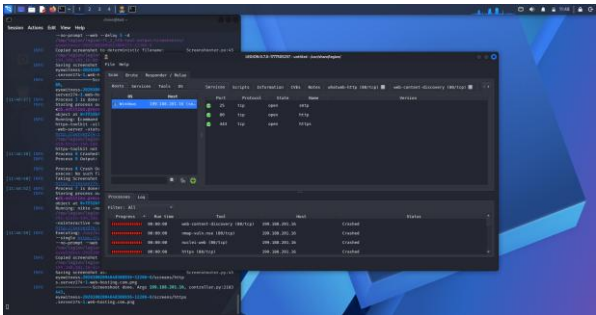


Figure 5: Legion service discovery showing SMTP, HTTP and HTTPS.

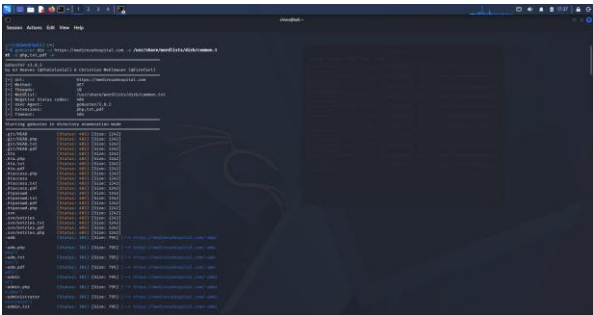


Figure 6: Gobuster directory and file enumeration.

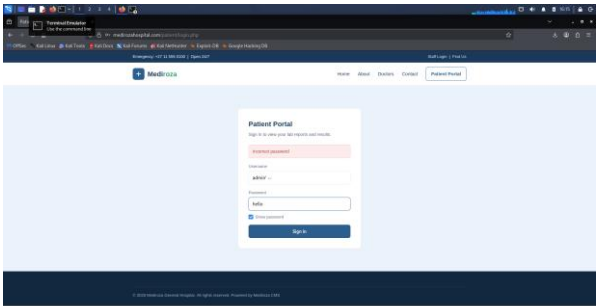


Figure 7: Controlled SQL injection test against the patient login.

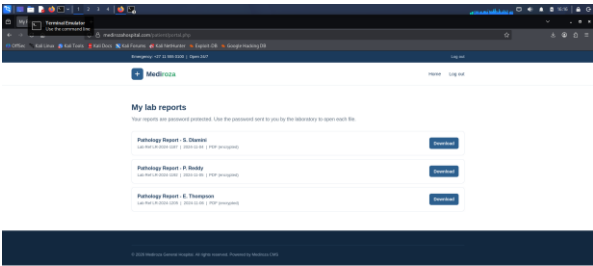


Figure 8: Patient portal showing the three encrypted pathology reports.

-End-